
Sample Compliance Manual

Page 1 — Introduction & Scope

This Compliance Manual sets forth the standards governing Anti-Money Laundering (AML), Data Privacy, and Operational Risk Management across the enterprise. It applies to all employees, contractors, and third-party vendors engaged with the organization.

Compliance is not optional. Failure to adhere to these standards may result in disciplinary action, financial penalties, or regulatory sanctions.

The manual is designed to:

- Provide clear obligations for staff.
- Establish reporting thresholds and escalation procedures.
- Ensure alignment with national and international regulatory frameworks.

Page 2 — Anti-Money Laundering (AML) Obligations

Transaction Monitoring

- All transactions exceeding **USD 10,000** must be reported to the Compliance Office within **24 hours**.
- Transactions involving foreign accounts must be flagged for enhanced due diligence.

Suspicious Activity Indicators

Employees must be alert to:

- Structuring deposits to avoid reporting thresholds.
- Rapid movement of funds between unrelated accounts.
- Use of shell companies with unclear ownership.
- Transactions inconsistent with customer profiles.

Training & Certification

- AML training is mandatory annually for all employees.
- Certification records must be retained for **5 years**.

Page 3 — Data Privacy & Protection

Data Storage

- Personal data must be stored in encrypted databases using **AES-256** encryption.
- Access is restricted to authorized personnel with role-based permissions.

Retention Policy

- Customer records retained for **7 years**.
- Employee records retained for **5 years** post-employment.
- Exceptions require written approval from the Data Protection Officer.

Breach Notification

- Any suspected data breach must be reported within **72 hours**.
- The Data Protection Officer must notify regulators and affected individuals promptly.

Employee Responsibilities

- Do not share passwords or credentials.
- Report phishing attempts immediately.
- Ensure laptops and mobile devices are encrypted.

Page 4 — Operational Risk Management

Risk Assessments

- Departments must conduct quarterly risk assessments.
- High-risk findings must be escalated to the Risk Committee within **7 business days**.

Business Continuity

- Continuity plans must be tested annually.
- Disaster recovery drills must be documented and reviewed.

Vendor Compliance

- Vendors must provide proof of compliance with **ISO 27001** standards.

- Contracts must include clauses requiring adherence to organizational compliance policies.

Incident Reporting

- Operational incidents must be logged within **24 hours**.
 - Escalation procedures must be followed for severe disruptions.
-

Page 5 — Audit & Enforcement

Internal Audits

- Conducted semi-annually by the Internal Audit Department.
- Findings must be documented and shared with senior management.

External Audits

- Regulators may initiate audits at any time.
- Full cooperation is required; obstruction may result in penalties.

Penalties for Non-Compliance

- Minor violations → Written warning.
- Major violations → Suspension or termination.
- Regulatory breaches → Reported to authorities.

Audit Logging

- All compliance actions must be logged in the **Audit Management System**.
 - Logs must include timestamp, actor, event type, and description.
-